AEGISAI ENTERPRISE EDITION

TECHNICAL DOCUMENTATION SUITE

End User & Auditor Manual

Operational Guide for AI Architecture Assessment & Verification

Platform Version:	**2.5.0 Enterprise Edition**
Compliance Scope:	**OWASP AISVS v1.0, ISO/IEC 42001:2023, Google Cloud Security**
License:	**Apache License 2.0 (Open Source)**

AEGIS AI ASSURANCE PLATFORM

End-User Manual and Official Operational Guide

Platform Version: 2.5.0 Enterprise (2026 Edition)

Classification: Official Documentation for Users and Compliance Officers

Covered Standards: OWASP AI-SVS 1.0, ISO/IEC 42001:2023, Bring Your Own Framework (BYOF: LFPDPPP, LFPC, EU AI Act)

---

1. Introduction and Overview

1.1 What is AegisAI?

AegisAI is an enterprise platform designed to automate security auditing, algorithmic risk analysis, and regulatory compliance certification in Artificial Intelligence (AI) and Large Language Model (LLM) based applications.

AegisAI evaluates technical architecture, Retrieval-Augmented Generation (RAG) components, vector stores, autonomous agents, and underlying infrastructure against the world's strictest international frameworks and territorial laws.

1.2 AegisAI Guiding Principles

The platform operates under four immutable assurance principles:

1. **Deterministic Hyper-Factual Inference:** Evaluations are executed with strict parameters (`temperature: 0.0` , `topK: 1` , `topP: 0.0`), eliminating any hallucinations in compliance rulings.
2. **Mandatory Textual Evidence:** No control can be rated as "Passed" unless there is an explicit textual citation extracted from the system's documentation. In its absence, the system issues "Missing Evidence".
3. **AI Shared Responsibility Model:** When the audited architecture runs on fully managed services like **Google Gemini Enterprise SaaS**, the platform automatically credits safeguards contractually guaranteed by the provider (Zero Data Retention, physical shielding of foundational weights, ISO 27001/42001/SOC 2 certifications).
4. **Log Immutability (OWASP AISVS Invariant 4):** Once an audit is concluded, its report and scores are unalterable and cryptographically secured for forensic and regulatory audits.

---

2. System Navigation Map

The AegisAI user interface consists of a quick-access sidebar with the following main views:

Module	Icon	Operational Purpose
Dashboard	📊	Executive panel with posture KPIs, metrics per standard, pass rate, and historical list of immutable audits.
New Audit	🛡️	Interactive 4-section form to parameterize the architecture and launch the evaluation.
Standards Catalog	📚	Interactive library featuring the 12 chapters of OWASP AI-SVS 1.0, the 10 domains of ISO 42001, and the laws from the BYOF module.
System Architecture	🏗️	Viewer for AegisAI's reference security topology, microservices, and data flow.
Configuration & Admin	⚙️	Administration panel for tokens, Gemini API keys, telemetry, and connectivity tests.

3. Normative Frameworks and Supported Laws

AegisAI allows auditing systems under 4 regulatory modalities:

3.1 OWASP Artificial Intelligence Security Verification Standard (AISVS 1.0)

Designed specifically for technical cybersecurity in AI. It consists of 12 canonical chapters:

- `C01` : Training Data Integrity and Traceability.
- `C02` : Input Validation and Defense against Prompt Injections.
- `C03` : Model Lifecycle Management and Cryptographic Versioning.
- `C04` : Infrastructure Security and Isolation in Containers / MicroVMs.
- `C05` : Access Control, Identity, and DEK Management.
- `C06` : Supply Chain Security (AIBOM and SCA scanning).
- `C07` : Model Behavior and Secure Output Handling (Anti-XSS).
- `C08` : Memory, Embeddings, and Vector Databases (ACLs in RAG).
- `C09` : Agentic Orchestration, Tools, and Human-in-the-Loop.
- `C10` : Model Context Protocol (MCP) Security and TLS 1.3.
- `C11` : Adversarial Robustness and Denial of Wallet (DoW) Prevention.
- `C12` : Continuous Monitoring, Auditing, and WORM / SIEM Traceability.

3.2 ISO/IEC 42001:2023 (Artificial Intelligence Management System - AIMS)

International standard for corporate governance, ethical risk management, and the AI lifecycle within organizations (10 domains and 38 controls from Annex A).

3.3 Federal Law on Protection of Personal Data Held by Private Parties (LFPDPPP - Mexico / INAI)

Mandatory legal framework in Mexico for processing user data in AI systems:

- Principles of lawfulness, loyalty, and minimization in prompts (`CAP-01`).
- Comprehensive privacy notice and express consent for biometric data (`CAP-02`).
- Encryption of RAG vector databases and PII redaction with DLP (`CAP-03`).
- Effective exercise of ARCO Rights and vector purging for the right to be forgotten (`CAP-04`).
- International transfers to clouds with Zero Data Retention guarantees (`CAP-05`).

- Detection of data exfiltration via prompt injection (`CAP-06`).

3.4 Federal Consumer Protection Law (LFPC - Mexico / PROFECO)

Mandatory legal framework in Mexico for customer service chatbots, quoting tools, and e-commerce:

- Mandatory identification that the user is speaking with an AI bot (`CAP-01`).
- Factual grounding in pricing and binding nature of reported offers (`CAP-02`).
- Prior purchase summary and legal right of withdrawal within 5 business days (`CAP-03`).
- Prohibition of discriminatory pricing via algorithmic profiling (`CAP-04`).
- Unrestricted escalation to human agents and ticket numbers for PROFECO complaints (`CAP-05`).
- PCI-DSS isolation of payment methods and reversal of unauthorized charges (`CAP-06`).

3.5 European Union Artificial Intelligence Act (EU AI Act)

Regulation (EU) 2024/1689 for high-risk AI systems (risk management, training data, transparency, and cybersecurity).

---

4. Step-by-Step Guide: How to Perform an Audit

Step 1: Initiate the Assessment

1. Go to the sidebar and click on "**New Audit**" or press the "**+ New Audit**" button on the Dashboard.
2. You will access the interactive form divided into 4 sequential sections.

Step 2: Configure Section 1 - Regulatory Framework Selection (Simultaneous Audit)

AegisAI allows you to select one or multiple regulatory frameworks to evaluate them concurrently in a single execution:

- **Multi-Selection Cards:** Check the boxes corresponding to the required standards (OWASP AI-SVS 1.0, ISO/IEC 42001:2023, Mexico LFPDPPP, Mexico LFPC, EU AI Act, or custom frameworks).
- **One-Click Quick Access:**
- 🌟 **Comprehensive 360° Audit (4 Standards):** Jointly evaluates AISVS + ISO 42001 + LFPDPPP + LFPC in a single run.
- 🇲🇽 **Mexican Laws:** Jointly evaluates LFPDPPP (Privacy / INAI) and LFPC (Consumer / PROFECO).
- 🛡️ **Dual Technical:** Jointly evaluates OWASP AISVS (Technical Security) and ISO 42001 (AIMS Governance).
- **Individual:** Select only the desired standard if you are looking for a targeted audit.
- **Dynamic Summary:** A bottom banner lists all active standards and enables quick removal with a single click.

Step 3: Configure Section 2 - OWASP AI-SVS Verification Level

- **AI Auto-Detect (Recommended):** Analyzes system risk and automatically assigns the level in compliance with the EU AI Act and OWASP AISVS.
- **Level 1 (L1 - Essential):** For basic productivity applications.
- **Level 2 (L2 - Standard):** For systems with PII, corporate RAG bases, or customer support.
- **Level 3 (L3 - Critical):** For financial systems, medical systems, or transactional autonomous agents.

Step 4: Configure Section 3 - System Data and Architecture

- **System Name:** Official name of the application (e.g., *BancaMovil AI*).
- **Technical Lead and Email:** Technical responsible party for the system in the RACI matrix.

- **Technical Documentation:** Attach specifications in `.pdf`, `.txt`, or `.md` format, or paste the architecture text into the text box. You can input specifications longer than 50 pages (up to 1,000,000 characters).

Step 5: Configure Section 4 - Platform and Shared Responsibility

Indicate the infrastructure your system runs on:

- **Google Gemini Enterprise (SaaS):** Automatically credits Google Cloud guarantees (Zero Data Retention, microVMs, ISO 27001/42001/SOC 2 certifications).
- **Google Cloud Vertex AI (PaaS):** Credits endpoint isolation, CMEK, and VPC-SC.
- **Azure OpenAI / AWS Bedrock:** Corresponding PaaS profiles.
- **Self-Hosted (Open-Weights):** Requires the user to demonstrate 100% of the infrastructure and weight signing.
- **AI Auto-Detect:** The engine analyzes the documentation and selects the ideal profile.

Step 6: Launch and Monitor the Audit

1. Click "**Run Multi-Standard Audit**" (the button dynamically reflects the number of selected standards).
2. Observe real-time progress via the Server-Sent Events (SSE) streaming console. The Map-Reduce pipeline will process batches sequentially, transmitting the active stage and percentage.
3. Upon completion, you will be automatically redirected to the **Compliance 360°** results view.

4.1 Live Google Cloud Project Auditing (GCP Live Scanner - Zero-Footprint)

If your organization operates AI workloads on **Google Cloud**, AegisAI allows you to audit live infrastructure directly by connecting to the official management APIs (Cloud Control Plane), without needing to draft documents or manually upload files.

A. Zero-Footprint Invariant

- **Zero Resources Created:** No software, agent, Cloud Function, virtual machine, or bucket is installed in the client's project.
- **Strictly Read-Only Requests:** The module only performs metadata query `HTTP GET` calls. No resources or IAM permissions are modified.

B. Steps to Audit a Live Project

1. In the sidebar, click the "**Audit Google Cloud**" option (cloud icon).
2. **Select the Authentication Method:**
   - **Demo / Simulation:** Loads a pre-configured enterprise stack (`aegis-fintech-ai-prod`) with Vertex AI, Cloud Run, Cloud Storage, and IAM for immediate testing without credentials.
   - **ADC / Cloud Run:** Native automatic connection if AegisAI runs on Cloud Run or in an environment with active Application Default Credentials.
   - **Temporary Token:** Enter an access token generated with `gcloud auth print-access-token`.
   - **Service Account:** Paste the JSON of a service account with a read role; authentication is signed in volatile memory without persisting the file.
3. **Specify the Project ID:** Enter the ID of the project to audit and press "**Test Connection**" to validate permissions.
4. **Select Components to Inspect:** Check the boxes for Vertex AI, Cloud Run, Cloud Storage, IAM, and Secret Manager/KMS.
5. **Choose Compliance Standards:** Select the desired frameworks (e.g., preset ⚡ 360° or 🇲🇽 Mexican Laws).

6. **Click "Scan and Audit":**
    - The scanner will collect real-time telemetry and output the inventory of discovered assets.
    - The AI engine will evaluate the actual infrastructure and generate the report with citations to specific resources (e.g., `gs://bucket-transcripts`, `endpoints/12345`).

---

5. BYOF Module: Ingestion of New Laws or Policies

AegisAI enables any organization to audit systems against its own internal policies or local regulations without writing code:

1. Go to **"Standards Catalog"** > **"Laws and Policies (BYOF)"** tab.
2. Click the top button **"+ Ingest New Law or Policy"**.
3. In the popup modal, choose whether to upload a file (PDF, DOCX, TXT, MD) or paste the text of the law/policy.
4. Type the name of the regulation (e.g., *CNBV Single Circular for Banks*) and the jurisdiction.
5. Click **"Start Regulatory Ingestion"**.
6. In approximately 570 milliseconds, the Gemini Flash-Lite model will break down the law into chapters and controls with atomic identifiers, test criteria, and mitigation recipes.
7. Click **"Audit with this Framework"** to evaluate any system against the new law immediately, or select it alongside other standards in the main form.

---

6. Interpretation of the Technical Report and Action Plans

6.1 Report Structure

- **Header and 360° Badge:** Displays the unique ID, date, technology platform, and whether it corresponds to an individual audit or a **360° Multi-Regulatory** audit.
- **Multi-Regulatory Dashboard Panel (Compliance 360°):** When evaluating multiple standards simultaneously, it displays a card matrix with the independent score for each standard (0-100%), visual progress bar, proportion of approved controls, and a quick filtering button.
- **Standard Filtering Tabs:** In the left sidebar, allows filtering chapters to view "All" or isolate only chapters from "OWASP AISVS", "ISO 42001", "LFPDPPP", "LFPC", etc.
- **Shared Responsibility Banner:** Details the controls credited through formal cloud inheritance.
- **Scope Filtering Tabs:** Allow visualizing "All Controls", "Mandatory L1-L3", "Top Recommendations", or "Platform-Inherited".

6.2 Regulatory Control States

- **Approved (Green):** The document satisfactorily demonstrates the implementation of the requirement.
- **Approved [Inherited] (Green with blue badge):** The requirement is covered by the cloud service contract (SaaS/PaaS).
- **Requires Review (Amber):** The control exists but lacks technical robustness (partial score).
- **Missing Evidence (Red):** The documentation does not mention the mandatory requirement (0% on the control).
- **Not Applicable (Gray):** The component is not part of the system.

6.3 Four-Dimensional (4D) Mitigation Recipes

Each non-compliant finding contains a collapsible tab with:

1. **Strategy:** Applicable defense architectural principle.
2. **Actionable Steps:** Concrete, sequential tasks for the development team.
3. **Code or Configuration:** Production-ready Kubernetes, Docker, TypeScript, or Python manifests.
4. **QA / Pentesting Recipe:** `curl` commands or automated testing scripts to verify the gap closure.
5. **Effort and Tools:** Estimated time (*Quick Win < 1 day, Medium 1-3 days, Structural > 1 week*) and recommended tools (*Microsoft Presidio, Sigstore, gVisor*).

6.4 Inference Engine Telemetry in the Report

A real-time telemetry card is displayed at the header of the audit report:

- **AI Model Used:** Shows the exact model that solved the audit (e.g., `gemini-3.8-flash`, `anthropic/claude-3.7-sonnet`, `gpt-4o`).
- **Inference Latency:** Total time in milliseconds the evaluation took.
- **Token Consumption:** Audited count of input tokens (`promptTokens`) and generated tokens (`completionTokens`).

6.5 Remediated Architecture Download (100% Compliance)

If the audit presents areas of opportunity or controls in `Failed` or `Missing Evidence` status, the platform automatically enables the **Suggested Fixes** panel:

1. **Quick Access:** Click the **"Suggested Fixes (.md)"** button in the top report bar or in the highlighted emerald panel.
2. **Preview Modal:** Allows interactively exploring the complete corrected architecture, with syntax highlighting and a **Copy to Clipboard** button.
3. **Specification Download (.md / .txt):** Downloads the *Drop-in Replacement* file that integrates the original architecture along with all safeguards (anti-injection sanitization, DLP anonymization, per-tenant RAG, WORM logs, and human escalation).
4. **Re-audit:** Allows automatically uploading the corrected document in a new audit to certify achieving **100.0% compliance**.

6.6 Formal Export

- **Export Markdown (.md):** Downloads the structured action plan with a RACI matrix, ideal for syncing with Jira or Confluence.
- **Export Official PDF:** Downloads the high-quality corporate document with a formal signature table for CISO approval.

7. Frequently Asked Questions (FAQ)

Q: Why can't I delete a past audit?

A: Due to the strict requirement of **OWASP AI-SVS Invariant 4** and ISO assurance standards, audits are legally immutable to prevent the erasure of evidence in security investigations or compliance fraud cases.

Q: What happens if my architecture document exceeds 50 pages?

A: AegisAI features a Map-Reduce architecture with an input window of up to 1 million characters. You can upload the complete document without fear of truncation.

Q: How do I know which controls Google Cloud covers in Gemini Enterprise?

A: In the audit report, click on the "Platform Inherited" tab. There you will see the foundational weight protection controls, microVMs, and Zero Data Retention formally accredited with citations from ISO 27001, ISO 42001, and SOC 2 certifications.